〔NEXUS WORK 조 회의록 및 활동일지〕 2026.10.20(화)

■ 활동 날짜 및 참여 조원

· 날짜: 2026-10-20(화), 개별 작업 + Notion 작업 보고서 공유

· 참여: 진혜정(조장), 홍주형, 이시헌, 김태빈

■ 오늘의 목표

· n8n 자동 대응(계정 잠금·세션 종료)을 실제 포털 DB에 연결해 시험

· pfSense·Graylog·n8n·Wazuh 통신표를 재점검하고 공격 재현(Kali) 경로 복구

· Graylog/Wazuh 이식 패키지 준비 및 n8n 최종 후보 workflow 등록(비활성)

■ 조원별 활동 내역

▶ 진혜정 (자동화·n8n·상황판)

· n8n 대응 워크플로 구현: R1 계정 잠금, R3·R11·R12 세션 종료 — 기본 dry-run, live 지정 시에만 실행하고 조치 후 재조회로 결과를 티켓 기록에 남김

· 홍주형이 준비한 n8n 전용 DB 계정(수정 가능 열: locked_until, session_version만)으로 실제 포털 DB에 연결해 계정 잠금·해제·세션 종료 동작을 확인(잠금 15분 설정, 해제 시 NULL, 세션 2→3)

· 해제 절차와 4번째 티켓 유형 "오탐·해제 요청" 구현 — 상황판 버튼·등록 폼 추가, 권한 밖 요청(토큰 없음·존재하지 않는 티켓 등)은 400/401/404로 거부되는 것까지 확인

· 10/21 항목 선작업: 티켓 4종 필드·상태 흐름 반영, R1~R12 목업 13건 n8n 내부 분류 사전 검증(13건 전부 일치), 웹훅 인증 보강(쿼리 토큰 대안), 팀원·강사님 IP 화이트리스트 등록, Graylog→n8n 연결 안내 문서 작성

▶ 홍주형 (웹·DB 하드닝)

· n8n 전용 DB 계정·3307 포트 n8n 장비 전용 개방(Windows 방화벽 차단 규칙으로 장비 제한, Docker 특성상 MySQL 계정만으로는 제한 불가함을 확인)

· AI 어시스턴트 실사용 가능하도록 구현 — Groq 기본, 질문자 권한 범위 자료만 참고하도록 제한. 최고관리자 고정은 admin·hongjh 두 계정으로 한정, 사용자 삭제·재입사 복구 기능 추가

· 로그인 후 첫 화면을 그룹웨어 대시보드로 전환(결재·업무·일정·근태 통합, 출퇴근 버튼), 부서 선택/변경 UI 추가(본인 부서 변경은 차단)

· 다른 세션/Antigravity가 작업하던 메신저 파일 전송·자동 업데이트·프로필 사진 기능을 이어받아 보안 검토 후 마무리(서명 검증 없는 설치 파일 실행 등 문제 5건 발견·수정 후 반영)

· 이시헌의 내부 API, 김태빈의 AI 첨부 기능 반영, 담당 8개 항목 점검 중 빠져 있던 AI 제한 열(R3 대응) 추가, 보안 이벤트 목록(86종)·AI 연결 지점 문서 정리

▶ 이시헌 (네트워크)

· 장비 간 통신표 재확인 중 pfSense 포털용 NAT 규칙이 잘못된 대상(192.168.3.10, 자기 자신)으로 설

정된 것을 발견해 192.168.3.14로 정정, LAN 규칙 목적지도 일치시켜 Kali→pfSense→포털 경로 복구

· NAT의 "Filter rule association"이 Pass로 설정돼 방화벽 규칙 검사를 우회하던 문제 해결(차단 목록에 IP를 넣어도 실제로는 안 막히던 원인), pfSense 방화벽 로그의 Graylog(filterlog) 도착 확인

· n8n↔pfSense 인라인 차단 연동 신규 구축: 전용 SSH 키 + 중계 서버(bridge.py)로 n8n이 NEXUS_AUTO_BLOCK 별칭을 직접 추가·제거, 화이트리스트(whitelist.csv)로 인프라 IP 보호 — 실제 IP(172.16.50.10) 차단 시 즉시 000, 해제 시 200으로 복구되는 것까지 검증

· 팀원·강사 IP 제외 목록을 차단 자동화 도구에 반영, 등록 IP는 skipped: whitelisted로 거부되는 것 확인

· Kali 공격 재현 스크립트(kali_replay.py) 5단계 통합 완료 — 1(계정침해)·2(인젝션 게시)·3(AI 악용 시도, AI가 정책상 거부)까지는 성공, 4단계(내부 API 호출)는 라우트 미배포(404)로 막혔다가 담당자 배포 후 성공(200), 5단계 FLAG 획득(FLAG{826feddc7e25b0a399f63e51})

· Discord 알림 포맷을 이모지 과다에서 제목·이벤트 줄 중심으로 축소, 위협 지표 9종 전종 시험으로 경보 발동·Discord 전달 확인 — 그 과정에서 같은 이벤트를 감지하는 경보 규칙이 두 세트(기존 〔NEXUS〕… 세트 + 신규 NEXUS T1~W1 9개) 겹쳐 중복 전송되던 문제를 발견, 신규 9개를 비활성화

· Kali-renox(192.168.3.11, 실제 LAN)와 pfSense(172.16.50.0/24, VMware 전용망)가 서로 안 보이는 문제를 Windows netsh portproxy 중계로 해결(이 PC 자체 시험은 200 확인, Kali-renox 실제 접속 확인은 남음)

▶ 김태빈 (탐지)

· TB(탐지) 보안 관제 변경의 main 통합 상태를 확인하고, 원본 n8n v2 workflow 기준 최종 dry-run 후보를 준비해 현재 n8n에 비활성 상태로 등록(기존 축소 dry-run workflow는 삭제하지 않고 비활성화 유지)

· Graylog/Wazuh export 이식 패키지 작성 — GELF/Raw UDP Input, NEXUS_AUTH/NEXUS_AI_SECURITY/NEXUS_WEB Stream 및 R1/R2/R5~R10 Event Definition을 다른 PC로 옮길 수 있도록 이름 기반 재탐색 구조로 정리(내부 ID·토큰 값은 패키지에 넣지 않음). Wazuh는 FIM·FIM 전달 설정 템플릿만 포함, 이번 적용 과정에서 Graylog 탐지 조건·Stream·Wazuh 설정 자체는 변경하지 않음

· 최종 후보 "NEXUS 탐지 알림 수신 v2 - 최종 후보 (DRY-RUN)"를 원본 v2 30개 노드를 보존해 공식 CLI로 import(36개 노드, 37개 연결, 비활성 상태로 등록만 완료, publish/activate는 하지 않음)

· Graylog R2 Notification이 현재 Basic Auth로 POST /webhook/nexus-alert에 전송 중인데, 최종 후보는 x-webhook-token Header Auth를 요구해 인증 방식이 아직 일치하지 않는 것을 확인 — credential 정리는 다음 작업으로 남김

■ 조원별 의견 및 제안 사항

· 진혜정: 자동 대응을 실제 DB에 적용하기 전 시험용 DB(Docker)로 먼저 검증하는 절차가 실수를 막는 데 유효했음, 해제 경로(오탐 포함)는 자동 조치와 반드시 세트로 설계해야 한다는 점을 재확인

· 이시헌: 같은 물리망 안에서는 IP 허용목록만으로 pfSense 경유/직접 접속을 구분할 수 없다는 걸 이번에 체감, 포털 자체에서 인바운드 인터페이스를 제한하는 조치가 따로 필요

· 김태빈: 운영 중인 v2를 건드리지 않고 최종 후보를 별도 workflow로 비활성 등록해 두는 방식이, 추후 전환 시 롤백 리스크를 줄여줄 것으로 기대

■ 회의 결과 및 결정 사항

1. 고정(pinned) 계정은 잠금 없이 세션 종료만 자동 처리, 잠금은 알림 뒤 사람이 승인(공격 팀의 고의적 전체 잠금으로 인한 방어 마비 방지)

2. n8n의 포털 DB 접속은 전용 계정 + 수정 가능 열 제한(locked_until, session_version) + 방화벽 IP 제한으로 확정

3. Graylog/Wazuh 설정은 이식 패키지로만 준비하고 다른 PC에는 아직 Apply하지 않기로 함

4. R2 Notification 인증 방식(Basic Auth → x-webhook-token) 불일치는 다음 작업에서 정리

■ 프로젝트 진행 상황 및 어려운 점

· 진행 상황

- n8n 자동 대응(계정 잠금·세션 종료·해제)이 실제 포털 DB 기준으로 동작 확인됨
- pfSense NAT 오류 수정으로 Kali 공격 재현 경로가 복구되고 5단계 전체(FLAG 획득)까지 성공
- Graylog/Wazuh 이식 패키지와 n8n 최종 후보 workflow가 비활성 상태로 준비 완료

· 어려운 점

1. 같은 이벤트를 감지하는 Graylog 경보 규칙이 중복 등록돼 Discord에 중복 전송되는 문제가 있었음(신규 9개 비활성화로 정리)

2. 여러 도구·세션이 같은 파일(메신저 API)을 동시에 고쳐 추적에 시간이 소요됨

3. Graylog R2 Notification 인증 방식이 n8n 최종 후보의 요구 방식과 일치하지 않아 아직 실제 연동은 보류 상태

■ 향후 활동 계획 및 역할 분담

· AI와 무관한 규칙(R1, R5~R10)을 실제 Graylog·n8n에 연결하고 통합 점검 1차 진행(전체)

· n8n 최종 후보의 인증 방식(x-webhook-token)에 맞춰 Graylog Notification 설정 정리(김태빈)

· 고정 계정 범위 최종 확인 및 방어전 전 시험 계정 비밀번호 변경(홍주형·진혜정)

· 포털 직접 접속 차단 적용, Kali-renox 실제 접속 확인(이시헌·포털 담당)

· 티켓 영구 저장소 이전, AI 연동 후 AI Tool 제한·토큰 폐기 대응 연결(진혜정)

■ 증거 자료

· 조원별 작업 보고서: 팀 Notion '회의 및 작업내용'(10/20) 페이지

- 진혜정 - 10/20 작업 / 2026-10-20 (화) 회고 — NEXUS WORK(홍주형) / 10/20 작업 내용 정리 보고서(이시헌) / 2026-10-20 작업 기록(김태빈, 개인 워크스페이스)